

CYBERSECURITY GAP ASSESSMENT

Redacted version | Customer requirement, evidence and remediation review

INTERNAL WORKING ASSESSMENT - NOT A CUSTOMER SUBMISSION, FORMAL AUDIT OR CLAIM OF COMPLIANCE

DOCUMENT ID	[REDACTED]
VERSION	1.0
PREPARED BY	Adrián Alejandro Becerril Ureña
ROLE	GRC Readiness Proposal Lead
DATE	14 August 2026

Classification: Confidential - Internal and Authorized Partner Use
Typography: IBM Plex Sans (font substitution may occur if not installed on the viewing device).

Document Control

Assessment owner	Executive Management / ISMS Coordinator	Review cycle	Until customer response is approved
Prepared by	Adrián Alejandro Becerril Ureña	Role	GRC Readiness Proposal Lead
Assessment basis	Customer B third-party cybersecurity requirements	Requirement count	71
Classification	Confidential	Language	English
Status	Working gap assessment	Evidence status	Incomplete / requires owner validation

Assessment Positioning

This assessment concerns real clients. To protect their confidentiality, client names and identifying details have been removed or anonymized in this redacted version. Organization A denotes the assessed organization, and Customer B denotes its customer. The assessment findings and recommendations have otherwise been preserved.

The Customer B questionnaire triggered this review. The questionnaire was part of their vendor risk toolkit.

Contents

1. Executive Summary	7. Conclusion
2. Business Context and Commercial Exposure	Appendix A. Original Customer B Requirement Register
3. Assessment Method	Appendix B. Finding Crosswalk
4. Consolidated Findings	Appendix C. Evidence Request List
5. Remediation Plan	Appendix D. References
6. Customer Response Rules	

1. Executive Summary

Customer B asks third parties to state a current maturity level, cite supporting evidence and provide comments. The expected maturity in the supplied requirement set is predominantly Level 3 - Defined, with selected controls at Level 4 - Managed. The supplied register contains 56 Level 3 requirements and 15 Level 4 requirements.

Overall response readiness	Not ready for customer submission without evidence validation.
Primary issue	Available documentation did not substantiate many certification, defined-process or KPI claims.
Primary operational concerns	Identity lifecycle, CRM export, collaboration access, unmanaged devices, classification and data egress.
Recommended action	Validate high-risk access first, then build the evidence package and reassess each customer requirement.

1.1 Immediate Management Decisions

- Appoint owners for the Customer B response, evidence collection and technical validation.
- Authorize immediate review of separation access, CRM exports and sensitive collaboration platform permissions.
- Confirm the actual project value, margin and commercial deadline before approving remediation spend.
- Decide whether the objective is customer qualification only or a broader ISO/IEC 27001 readiness program.

2. Business Context and Commercial Exposure

Organization A operates as a medium sized engineering-services provider with work across multiple locations [REDACTED]. Relevant information may include CAD/CAE, blueprints, embedded software or firmware, customer contacts, commercial records and personnel information. This context increases the importance of customer-data segregation, identity management, controlled collaboration and secure engineering.

2.1 Commercial Business Case

The available assessment documents do not establish an awarded Customer B contract value. A reported qualified pipeline of approximately USD [REDACTED] is therefore used only as an interim commercial proxy and must be replaced with the approved Customer B opportunity value before this report is used for investment approval.

Input	Value / formula	Interpretation
Interim opportunity proxy	USD [REDACTED]	Illustrative only; not confirmed as Customer B-only or awarded revenue.
Potential revenue exposure	Up to the actual project value	Qualification delay or failure may put the opportunity at risk.
Expected exposure model	Project revenue x probability of qualification loss	Use management-approved probability and commercial data.
Remediation decision	Compare remediation cost with contribution margin and strategic value at risk	Do not compare security cost only with gross revenue.
Proxy sensitivity	Each 10% of qualification-loss probability equals USD [REDACTED] of expected revenue exposure	Based only on the interim USD [REDACTED] proxy.
BUSINESS RELEVANCE	The first remediation actions are mainly governance, access review and configuration validation. They can protect a customer opportunity while also creating reusable evidence for future clients and ISO readiness.	

3. Assessment Method

3.1 Sources and Limitations

- Customer B Third Party Cyber Security Self-Assessment requirement set and evaluation method supplied by Organization A.
- Information provided about Organization A operations and technology use.
- Conditions observed during legitimate, authorized business activities.

- No penetration test, privilege escalation, unauthorized download, configuration audit or post-authorization access test was performed.

3.2 Customer B Maturity Interpretation

Level	Name	Assessment meaning
0	Nothing	No process or activity.
1	Initial	Informal individual practice.
2	Repeatable	Written or repeatable process followed by only part of the organization.
3	Defined	Process is defined, known and followed across the relevant organization.
4	Managed	Process is followed and measured with KPIs.
5	Optimized	Measured process is continuously improved.

Customer B also requires evidence for each control and evidence supporting any Not Applicable response. The expected level is the minimum maturity requested by the customer.

3.3 Risk Rating

Risk score = likelihood (1-3) x impact (1-3). Scores 1-2 are Low, 3-4 Medium, 6 High and 9 Critical. This report rates the business exposure of the finding, not only the technical weakness.

4. Consolidated Findings

The findings aggregate related Customer B requirements. The complete original requirement register appears in Appendix A.

F-01 - Security evidence could not substantiate the simulated maturity claims			HIGH
EVIDENCE BASIS	CONFIDENCE	RELATED CUSTOMER B REFS	STATUS
Evidence gap	High in the evidence gap; control implementation not verified	SEC-DOC-001 to SEC-DOC-006; SEC-CMP-001 to SEC-CMP-006; applies broadly	Requires validation
OBSERVATION	During preparation of the customer questionnaire, sufficient approved policies, certifications, system reports and operating records were not available to support many responses. Draft manual sections were used in the simulation as references for certifications or maturity, but a policy or proposal does not demonstrate certification or consistent operation.		
WHY IT MATTERS	The customer assessment may be rejected, delayed or treated as unreliable. Unsupported Level 3 or Level 4 statements can also damage trust if later challenged.		
RECOMMENDED ACTION	Create an evidence index, appoint owners, request the actual records and approve each response before customer submission.		
EVIDENCE EXPECTED	Certificate or report where requested; approved policy; operating record; KPI report for Level 4; reviewer approval.		

F-02 - Identity lifecycle and separation access require formal validation			HIGH
EVIDENCE BASIS	CONFIDENCE	RELATED CUSTOMER B REFS	STATUS
Direct observation	High in the observation; exact systems and timestamps require IT confirmation	SEC-HUM-003; SEC-AST-006; SEC-ACC-002, 003, 005 and 006	Requires validation
OBSERVATION	After the separation process had been communicated, access to certain corporate resources remained available for a long period. The assessment did not independently test every system or administrative configuration.		
WHY IT MATTERS	Former or transferred personnel may retain access to company or customer information. Active sessions, SaaS accounts and remote access can remain usable even if one account is disabled.		
RECOMMENDED ACTION	Create a joiner-mover-leaver workflow with an effective-time trigger, system checklist, session revocation, asset return and management confirmation. Validate initial credential change, MFA coverage and privileged access at the same time.		
EVIDENCE EXPECTED	HR notification; offboarding ticket; account-disable and session-revocation timestamps; asset-return record; completed checklist.		

F-03 - Bulk customer-data export capability requires role and monitoring review			HIGH
EVIDENCE BASIS Direct observation	CONFIDENCE High in the observed functionality; enterprise-wide entitlement scope not verified	RELATED CUSTOMER B REFS SEC-AST-002, 004 and 007; SEC-ACC-006, 008, 009 and 010; SEC-OPS-004 and 005	STATUS Requires validation
OBSERVATION	During authorized use of the CRM platform, bulk export functionality appeared available to the assessor account. No evidence was available showing separate approval, role restriction, alerting or periodic review of high-volume exports.		
WHY IT MATTERS	A compromised or misused account could extract a large amount of customer and commercial information quickly, increasing privacy, contractual and reputational exposure.		
RECOMMENDED ACTION	Review CRM roles, restrict bulk export to justified users, enable or retain export logs, alert on abnormal volume and review entitlements periodically.		
EVIDENCE EXPECTED	Role matrix; export permission configuration; export logs; alert rule; quarterly access review and exception approval.		

F-04 - Collaboration repository access requires least-privilege review			HIGH
EVIDENCE BASIS Direct observation	CONFIDENCE Medium-high; repository ownership and inherited permissions require administrator review	RELATED CUSTOMER B REFS SEC-ACC-002, 003, 006 and 009; SEC-COM-001; SEC-SUP-001	STATUS Requires validation
OBSERVATION	During normal work, access was available to multiple collaboration platform repositories and documents for which the business need was not always apparent. A current owner-based access certification was not available.		
WHY IT MATTERS	Broad group membership, inherited permissions or external links may expose sensitive documents beyond need-to-know and make accountability difficult.		
RECOMMENDED ACTION	Inventory sensitive sites and libraries, assign owners, review groups and inherited permissions, disable unnecessary public or guest links and certify access on a defined cycle.		
EVIDENCE EXPECTED	Site inventory; owner list; permission export; external-sharing report; signed access certification; remediation tickets.		

F-05 - Information classification and handling were not consistently visible			MEDIUM
EVIDENCE BASIS Direct observation	CONFIDENCE High for sampled documents; enterprise-wide coverage not tested	RELATED CUSTOMER B REFS SEC-HUM-001; SEC-AST-002 to 005; SEC-ACC-008; SEC-COM-004	STATUS Requires validation
OBSERVATION	Documents reviewed during normal business activities did not consistently show a classification label or handling instruction. No approved classification and handling matrix was available during the assessment.		
WHY IT MATTERS	Personnel may not know whether a file can be emailed, downloaded, externally shared, retained or deleted, leading to inconsistent protection of customer information.		
RECOMMENDED ACTION	Adopt a simple four-level classification scheme, define handling rules and pilot visible or automated labels on customer, engineering, HR and commercial information.		
EVIDENCE EXPECTED	Approved classification standard; handling matrix; labeled samples; training record; label or DLP configuration.		

F-06 - Access from unmanaged devices requires conditional-access review			HIGH
EVIDENCE BASIS Direct observation	CONFIDENCE Medium-high; tenant-wide policy and exceptions were not administratively reviewed	RELATED CUSTOMER B REFS SEC-ORG-003; SEC-ACC-001; SEC-PHY-006; SEC-OPS-002; SEC-COM-001	STATUS Requires validation
OBSERVATION	Corporate resources could be accessed during authorized work from personal computers or mobile devices. No evidence was available that device compliance, approved applications, download restrictions or selective wipe were consistently required for sensitive information.		
WHY IT MATTERS	Sensitive information may be cached, copied or retained on devices that Organization A does not manage, monitor, encrypt or wipe.		
RECOMMENDED ACTION	Define which systems require managed devices, implement MFA and conditional access, restrict downloads on unmanaged sessions and use mobile application protection where business use requires phones.		
EVIDENCE EXPECTED	Conditional-access policies; device-compliance report; managed-app settings; test results; approved exceptions.		

F-07 - Data-egress controls were not evidenced			HIGH
EVIDENCE BASIS Evidence gap and direct observation	CONFIDENCE Medium; endpoint and cloud-control configurations require validation	RELATED CUSTOMER B REFS SEC-ORG-004; SEC-AST-004 to 007; SEC-ACC-010; SEC-COM-004	STATUS Requires validation
OBSERVATION	No sufficient evidence was available that USB use, personal cloud storage, external email, mass downloads or other information-egress paths were consistently blocked, limited or monitored. Prior-employer practices were used only as a maturity benchmark, not as proof of Organization A deficiency.		
WHY IT MATTERS	Authorized users or compromised accounts may move customer or engineering information outside controlled systems without timely detection.		
RECOMMENDED ACTION	Implement a phased data-egress program: first gain visibility, then restrict obvious high-risk paths, and later apply rules based on classification, role, device and volume.		
EVIDENCE EXPECTED	USB/device-control settings; cloud-app discovery; DLP rules; mass-download alerts; exception register; monthly review.		

F-08 - Business continuity, recovery and incident readiness were not demonstrated			HIGH
EVIDENCE BASIS Evidence gap	CONFIDENCE High in the missing evidence; actual technical recovery capability not verified	RELATED CUSTOMER B REFS SEC-OPS-003 and 004; SEC-INC-001 to 003; SEC-BCP-001	STATUS Requires validation
OBSERVATION	A complete business impact analysis, approved business continuity and disaster recovery plans, restoration test, incident exercise and customer notification matrix were not available.		
WHY IT MATTERS	Organization A may be unable to demonstrate how critical engineering services will continue, how quickly data can be restored or how customer incidents will be communicated.		
RECOMMENDED ACTION	Identify critical services and dependencies, set RTO/RPO, validate backup coverage, run a restoration test and tabletop exercise, and define contractual notification rules.		
EVIDENCE EXPECTED	BIA; recovery plan; RTO/RPO register; backup and restore report; tabletop record; notification matrix.		

F-09 - Secure development and supplier assurance were not evidenced			HIGH
EVIDENCE BASIS Evidence gap	CONFIDENCE High in the missing evidence; current engineering practices require interviews and sampling	RELATED CUSTOMER B REFS SEC-ACQ-001 to 003; SEC-SUP-001 to 007	STATUS Requires validation
OBSERVATION	Evidence was not available for secure development requirements, separation of development/test/production, protection of source code and secrets, non-production test data, subcontractor due diligence or standard security clauses.		
WHY IT MATTERS	Customer information may be exposed through insecure development, shared environments or an unassessed supplier. Customer contractual requirements may not flow down to subcontractors.		
RECOMMENDED ACTION	Create a lightweight secure-development checklist and supplier-security process. Start with customer-data segregation, repository permissions, secrets, test data, NDA, right-to-audit and incident obligations.		
EVIDENCE EXPECTED	SDLC checklist; repository access; test/release records; supplier register; questionnaire; contract clauses; annual review.		

F-10 - Security governance, audit and risk authority were not formally established			HIGH
EVIDENCE BASIS Evidence gap	CONFIDENCE High	RELATED CUSTOMER B REFS SEC-ORG-001, 002 and 005; SEC-CMP-001 to 006	STATUS Requires validation
OBSERVATION	A formally appointed security officer or ISMS owner, risk acceptance authority, internal audit program, privacy/legal register, management-review record and KPI set were not available.		
WHY IT MATTERS	Customer responses and risk decisions may depend on individual judgment, findings may remain open, and the organization cannot demonstrate a managed improvement cycle.		
RECOMMENDED ACTION	Appoint an executive sponsor and coordinator, approve scope and risk criteria, maintain legal and customer obligations, schedule independent review and management review, and track corrective actions.		
EVIDENCE EXPECTED	Approved charter; roles/RACI; risk criteria; audit plan/report; management minutes; legal register; KPI report; CAPA tracker.		

5. Remediation Plan

Period	Priority activity	Exit evidence
0-15 days	Stop unsupported claims; appoint response owner; open evidence repository; validate active separation access; preserve available records.	Approved owner list; corrected response status; evidence index; access closure records.
16-30 days	Review CRM export rights and logs; review sensitive collaboration platform permissions and external sharing; confirm MFA and device-access posture.	Role and permission exports; remediation tickets; MFA/device-policy report.
31-60 days	Approve classification, access, offboarding, incident and supplier minimum procedures; address obvious USB/personal-cloud and unmanaged-device risks.	Approved procedures; labeled samples; device/DLP configurations; supplier register.
61-90 days	Run access review, restore test and incident tabletop; collect operating evidence; reassess all 71 requirements and obtain management approval.	Completed response matrix; evidence pack; test results; management sign-off.

6. Customer Response Rules

Response topic	Rule
Certification requests	Provide the actual certificate or independent report. A policy, risk method or draft manual is not equivalent.
Level 3 claims	Require an approved process, organization-wide adoption within scope and representative operating evidence.
Level 4 claims	Require useful KPIs, regular review, exceptions and evidence that the metrics drive decisions.
Not Applicable	Provide a clear reason and evidence supporting the exclusion.
Evidence references	Use a controlled evidence ID and exact document/report name, owner, date and version.

Response topic	Rule
Customer notification	Use the contractual and legal notification matrix; do not assume a universal 72-hour customer deadline.
Older standard references	Preserve Customer B wording but request clarification on whether current ISO editions are accepted.

7. Conclusion

The Customer B requirement set is a useful customer benchmark, but the current response package is not yet defensible as an evidence-based assessment. The immediate value of this exercise is not to manufacture a higher score; it is to identify what must be owned, operated and evidenced before Organization A makes a customer assurance claim.

The practical sequence is: validate the highest-risk access and data-movement concerns, build the evidence repository, implement the minimum governance and operational processes, and then reassess every requirement. This creates a credible customer response and reusable groundwork for the broader Organization A ISMS program.

Appendix A. Original Customer B Requirement Register

The requirements below retain the supplied wording, including original spelling and legacy standard references, except for anonymized client identifiers. The simulated Organization A evaluation, evidence references and comments have been removed. Expected Level is retained because it is part of the customer requirement.

Reference	Domain	Customer B requirement	Expected level
SEC-DOC-001	Information security policies	Indicate your level of maturity regarding the ISO/IEC 27001:2013 certification, and provide the evidence	3
SEC-DOC-002	Information security policies	Indicate your level of maturity regarding the ISO/IEC 27017:2015 certification, and provide the evidence	3
SEC-DOC-003	Information security policies	Indicate your level of maturity regarding the ISO/IEC 27018:2015 certification, and provide the evidence	3
SEC-DOC-004	Information security policies	Indicate your level of maturity regarding the SOC 1 or ISAE 3402 certifications, and provide the evidence	3
SEC-DOC-005	Information security policies	Provide the SOC 2 report (to be checked by Customer B security organization)	3
SEC-DOC-006	Information security policies	Provide your ISSP (to be checked by Customer B security organization)	3
SEC-ORG-001	Organization of information security	Precise if a supplier Security Officer is defined, and provide the evidence	3
SEC-ORG-002	Organization of information security	Describe your security organization (including responsibilities), and provide the evidence	3
SEC-ORG-003	Organization of information security	Provide your hardening policy regarding the mobile devices	3
SEC-ORG-004	Organization of information security	Indicate how you manage the external devices, describe the corresponding policy, and provide the evidence	3
SEC-ORG-005	Organization of information security	Describe how you manage major changes in organization and process in terms of security, and provide the evidence	3
SEC-HUM-001	Human resource security	Describe how you manage secret information, and provide the evidence (e.g. Specific NDA...)	4
SEC-HUM-002	Human resource security	Describe how you manage your employees' security awareness and training (particularly regarding security staff, confidential and secret information handling..), and provide the evidence	3
SEC-HUM-003	Human resource security	Indicate how you make sure your employees are engaged in a non disclosure agreement to protect confidential or secret information, and provide the evidence	3
SEC-AST-001	Asset management	Describe how you manage the confidentiality in your suppliers' contracts, and provide the evidence	3
SEC-AST-002	Asset management	Describe how you manage the assets handling Customer B data/information (classification, responsibility...), and provide the evidence	3
SEC-AST-003	Asset management	Precise how you manage the classification of your assets, and provide the evidence	3
SEC-AST-004	Asset management	Describe how you master the protection of the information depending on its classification, and provide the evidence	3
SEC-AST-005	Asset management	Describe how you guaranty the destruction of the Customer B information (process, techniques...), for instance on Customer B request, and provide the evidence	4
SEC-AST-006	Asset management	Describe how you manage an end of a contract (process, information destruction techniques...), and provide the evidence	3
SEC-AST-007	Asset management	Describe how you manage the protection, incident detection for the assets, and provide the evidence	4
SEC-ACC-001	Access management	Describe how you manage access to the platforms from external localization, and provide the evidence	4

Reference	Domain	Customer B requirement	Expected level
SEC-ACC-002	Access management	Indicate how you manage the 'Identity' and provisioning in your user access process, detail when it is related to third parties, and provide the evidence.	3
SEC-ACC-003	Access management	Indicate how you manage the 'Role' and provisioning in your user access process, detail when it is related to third parties, and provide the evidence.	3
SEC-ACC-004	Access management	Indicate how you manage the 'Authentication' in your user access process, detail when it is related to third parties, and provide the evidence.	4
SEC-ACC-005	Access management	Indicate how you manage the privileged accounts in your user access process, detail when it is related to third parties, and provide the evidence.	3
SEC-ACC-006	Access management	Describe how you master the access to sensitive platforms or information, and provide the evidence	3
SEC-ACC-007	Access management	Describe your password policy, and provide the evidence	3
SEC-ACC-008	Access management	Describe how you master the protection of the secret information, and provide the evidence	3
SEC-ACC-009	Access management	Describe your data access management when the access is not handled by an application, and provide the evidence	3
SEC-ACC-010	Access management	Describe how you manage the access to data received from a transfert, and provide the evidence	3
SEC-CRY-001	Cryptography	Indicate how you can authorize approved third-party or Customer B encryption techniques, and provide the evidence	4
SEC-CRY-002	Cryptography	Precise how you manage the encryption, and provide the evidence	3
SEC-CRY-003	Cryptography	Describe how you manage the backups (including encryption) containing confidential or secret information, and provide the evidence	3
SEC-PHY-001	Physical and environmental security	Indicate your level of hosting physical security, and provide the evidence (Datacenter certification)	4
SEC-PHY-002	Physical and environmental security	Describe how you manage the different physical zones according to their level of criticality, and provide the evidence	3
SEC-PHY-003	Physical and environmental security	Describe how you manage the physical access to assets, and provide the evidence	3
SEC-PHY-004	Physical and environmental security	Describe how you monitor the different physical zones according to their level of criticality, and provide the evidence	3
SEC-PHY-005	Physical and environmental security	Indicate how you are protected against natural threats, and provide the evidence	3
SEC-PHY-006	Physical and environmental security	Describe how you manage the use 'off-premises' of the assets, and provide the evidence	3
SEC-OPS-001	Operations security	Indicate how the different environments (Development, testing, production) are organized, and provide the evidence	3
SEC-OPS-002	Operations security	Describe how you manage the endpoint protection, and provide the evidence	3
SEC-OPS-003	Operations security	Describe how you manage the backups, and provide the evidence	3
SEC-OPS-004	Operations security	Describe how you manage the event logs, the possibility for Customer B to access it, and provide the evidence	3
SEC-OPS-005	Operations security	Indicate how you monitor non-authorized administration activities, and provide the evidence	3
SEC-OPS-006	Operations security	Describe your vulnerability management process, and provide the evidence	4
SEC-OPS-007	Operations security	Describe your patch management process, and provide the evidence	4
SEC-COM-001	Communications security	Describe how you manage access to Customer B data (including from external localization), and provide the evidence	3
SEC-COM-002	Communications security	Describe how you manage your network protection, and provide the evidence	3
SEC-COM-003	Communications security	Describe your network segregation strategy, and provide the evidence	4

Reference	Domain	Customer B requirement	Expected level
SEC-COM-004	Communications security	Describe how you protect the data during a transfert (internal or external), and provide the evidence	3
SEC-ACQ-001	Systems acquisition, development and maintenance	Indicate how you handle the different data needed in the different environments (Development, testing, production), and provide the evidence	3
SEC-ACQ-002	Systems acquisition, development and maintenance	Describe how you manage security during the development lifecycle, and provide the evidence	3
SEC-ACQ-003	Systems acquisition, development and maintenance	Confirm that no Customer B operational data is used for testing, and provide the evidence	4
SEC-SUP-001	Third party relationship	Indicate how you master the information and access segregation of your different customers, and provide the evidence	3
SEC-SUP-002	Third party relationship	Indicate how you can provide capability to dedicate environment to Customer B and limits (if any), provide the evidence	3
SEC-SUP-003	Third party relationship	Indicate how you can manage applications in Customer B environnement, and provide the evidence	3
SEC-SUP-004	Third party relationship	Describe how you manage the changes linked to security (communication to users, renewal of certifications...), and provide the evidence	3
SEC-SUP-005	Third party relationship	Indicate if subcontractors are involved. If so, indicate how you choose your third parties, make sure they are compliant with your customers' security rules and all of them have been declared. Provide the evidence	3
SEC-SUP-006	Third party relationship	Indicate how you make sure your subcontractors are engaged in a non disclosure agreement to be compliant with your customers' security requirements, and provide the evidence	4
SEC-SUP-007	Third party relationship	Provide the standard audit clause included in your subcontractors' contracts	3
SEC-INC-001	Information security incident management	Describe how you handle the monitoring in the security incident management process, indicate how it is taken into account in the improvement, and provide the evidence	3
SEC-INC-002	Information security incident management	Describe how you handle the reporting in the security incident management process (especially to Customer B), indicate how it is taken into account in the improvement, and provide the evidence	4
SEC-INC-003	Information security incident management	Describe how you handle the incident response in the security incident management process, indicate how it is taken into account in the improvement, and provide the evidence	3
SEC-BCP-001	Business continuity management	Describe your Disaster Recovery Plan and Business Continuity Plan process, and provide the evidence	4
SEC-CMP-001	Compliance	Describe your internal audit process, and provide the evidence	3
SEC-CMP-002	Compliance	Describe how you manage personal data, and provide the evidence you are compliant with privacy related laws or regulation (Europe)	3
SEC-CMP-003	Compliance	Describe how you manage the compliance with the laws of the different involved countries, and provide the evidence	3
SEC-CMP-004	Compliance	Describe how you manage personal data, and provide the evidence you are compliant with privacy related laws or regulation (Outside Europe)	4
SEC-CMP-005	Compliance	Describe your ISMS audit process, including third parties review, and prove that it is in a PDCA cycle, and provide the evidence	3
SEC-CMP-006	Compliance	Describe your internal audit organization with a focus on the ISSP check, and provide the evidence	3

Appendix B. Finding Crosswalk

ID	Finding	Risk	Related Customer B requirements
F-01	Security evidence could not substantiate the simulated maturity claims	High	SEC-DOC-001 to SEC-DOC-006; SEC-CMP-001 to SEC-CMP-006; applies broadly
F-02	Identity lifecycle and separation access require formal validation	High	SEC-HUM-003; SEC-AST-006; SEC-ACC-002, 003, 005 and 006
F-03	Bulk customer-data export capability requires role and monitoring review	High	SEC-AST-002, 004 and 007; SEC-ACC-006, 008, 009 and 010; SEC-OPS-004 and 005
F-04	Collaboration repository access requires least-privilege review	High	SEC-ACC-002, 003, 006 and 009; SEC-COM-001; SEC-SUP-001
F-05	Information classification and handling were not consistently visible	Medium	SEC-HUM-001; SEC-AST-002 to 005; SEC-ACC-008; SEC-COM-004
F-06	Access from unmanaged devices requires conditional-access review	High	SEC-ORG-003; SEC-ACC-001; SEC-PHY-006; SEC-OPS-002; SEC-COM-001
F-07	Data-egress controls were not evidenced	High	SEC-ORG-004; SEC-AST-004 to 007; SEC-ACC-010; SEC-COM-004
F-08	Business continuity, recovery and incident readiness were not demonstrated	High	SEC-OPS-003 and 004; SEC-INC-001 to 003; SEC-BCP-001
F-09	Secure development and supplier assurance were not evidenced	High	SEC-ACQ-001 to 003; SEC-SUP-001 to 007
F-10	Security governance, audit and risk authority were not formally established	High	SEC-ORG-001, 002 and 005; SEC-CMP-001 to 006

Appendix C. Evidence Request List

Domain	Minimum evidence request
Governance	Security officer/ISMS appointment; organization and RACI; approved ISSP; risk method/register; legal/privacy register; internal audit and management-review records.
Certifications	Current ISO/IEC 27001, ISO/IEC 27017, ISO/IEC 27018, SOC 1/ISAE 3402 or SOC 2 certificates/reports, or an explicit statement that they are not held.
People	NDA template and samples; onboarding/offboarding checklist; training content and completion; role changes and access revocation records.
Assets and data	Asset register; classification/handling standard; labeled samples; retention/deletion process; destruction records.
Access	Identity and role model; MFA configuration; privileged accounts; access reviews; remote and third-party access records.
Endpoint and network	MDM/EDR coverage; secure baseline; USB/device controls; patch and vulnerability reports; network diagram and segmentation.
Encryption and backup	Encryption/key configuration; backup architecture; backup jobs; restoration test; protected transfer methods.
Logging and incidents	Log-source/retention list; alert process; incident plan; notification matrix; incident register; tabletop and lessons learned.
Development	Environment segregation; SDLC standard; source-code permissions; secure testing; release and change records; test-data controls.
Suppliers	Supplier register; due diligence; NDA/security/right-to-audit clauses; subcontractor declaration and annual review.
Continuity	BIA; RTO/RPO; BCP/DR plan; recovery exercise; management-approved corrective actions.

Appendix D. References

- [1] Customer B. Third Party Cyber Security Self-Assessment - Evaluation Method (supplied document). (accessed 14 August 2026).
- [2] Customer B. Third Party Cyber Security Self-Assessment - Requirement Set (supplied document). (accessed 14 August 2026).
- [3] International Organization for Standardization. ISO/IEC 27001:2022 - Information security management systems - Requirements. <https://www.iso.org/standard/27001> (accessed 14 August 2026).
- [4] International Organization for Standardization. ISO/IEC 27001:2022/Amd 1:2024 - Climate action changes. <https://www.iso.org/standard/88435.html> (accessed 14 August 2026).
- [5] International Organization for Standardization. ISO/IEC 27002:2022 - Information security controls. <https://www.iso.org/standard/75652.html> (accessed 14 August 2026).
- [6] International Organization for Standardization. ISO/IEC 27005:2022 - Guidance on managing information security risks. <https://www.iso.org/standard/80585.html> (accessed 14 August 2026).
- [7] National Institute of Standards and Technology. The NIST Cybersecurity Framework (CSF) 2.0, CSWP 29. <https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-csf-20/final> (accessed 14 August 2026).
- [8] National Institute of Standards and Technology. NIST SP 1300 - CSF 2.0 Small Business Quick-Start Guide. <https://csrc.nist.gov/pubs/sp/1300/final> (accessed 14 August 2026).
- [9] National Institute of Standards and Technology. NIST SP 1301 - Creating and Using CSF Organizational Profiles. <https://www.nist.gov/publications/nist-cybersecurity-framework-20-quick-start-guide-creating-and-using-organizational> (accessed 14 August 2026).
- [10] National Institute of Standards and Technology. NIST SP 1302 - Using CSF Tiers. <https://www.nist.gov/publications/nist-cybersecurity-framework-20-quick-start-guide-using-csf-tiers> (accessed 14 August 2026).
- [11] National Institute of Standards and Technology. NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations. <https://csrc.nist.gov/pubs/sp/800/61/r3/final> (accessed 14 August 2026).
- [12] National Institute of Standards and Technology. NIST SP 800-63B-4 - Authentication and Authenticator Management. <https://csrc.nist.gov/pubs/sp/800/63/b/4/final> (accessed 14 August 2026).
- [13] National Institute of Standards and Technology. NIST SP 800-88 Rev. 2 - Guidelines for Media Sanitization. <https://csrc.nist.gov/News/2025/guidelines-for-media-sanitization-rev-2> (accessed 14 August 2026).
- [14] Center for Internet Security. CIS Critical Security Controls v8.1. <https://www.cisecurity.org/insights/white-papers/cis-critical-security-controls-v8-1> (accessed 14 August 2026).
- [15] Center for Internet Security. CIS Controls Implementation Group 1 - Essential Cyber Hygiene. <https://www.cisecurity.org/controls/implementation-groups/ig1> (accessed 14 August 2026).